MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 013 · AUGUST 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

EXPLAINER · SELF-ATTESTATION

Who Signs Your Self-Attestation, and What They Are Signing

Self-attestation is not a lighter version of an assessment. It moves the assessment risk onto a named individual - and the False Claims Act is where that lands.

BY **MACTECH SOLUTIONS** READING TIME · 4 MIN CMMC · COMPLIANCE · DEFENSE-CONTRACTING · GOVERNANCE

The word "self" is doing an enormous amount of damage in the phrase self-attestation. It suggests informality, an honor system, a lighter-touch alternative to being assessed by somebody else. What it actually describes is a transfer: the government has moved the burden of being right from an assessor onto a named person inside your company.

That person is the affirming official, and the interesting question is not what they attest to. It is what happens if they are wrong.

Where self-attestation is permitted, the organization performs its own assessment against the applicable controls, computes and posts a score, and a senior official affirms the result. No third party validates any of it before it becomes a representation to the government.

That is the entire mechanism, and it is why the conditions under which self-attestation is allowed matter so much - the path is narrower than most contractors assume, and assuming into it is itself a risk. But suppose you are genuinely eligible. The mechanism still leaves you with a signature that carries weight no internal document does.

FIELD COPY
ISSUE Nº 013
CMMC

1

NAMED INDIVIDUAL WHOSE SIGNATURE CARRIES THE REPRESENTATION

◆ **NOT A LEGAL OPINION**

This describes how the affirmation mechanism is structured and where enforcement has historically come from. It is not legal advice - if you are the person signing, that conversation belongs with counsel.

What the signature actually carries

An inaccurate SSP is a compliance problem. An inaccurate affirmation is a false statement made to obtain or keep a federal contract, and that is a different body of law entirely.

The Department of Justice has, through its Civil Cyber-Fraud Initiative, treated cybersecurity misrepresentations as False Claims Act matters - the same statute used for billing fraud. The relevant features for anyone about to sign: liability attaches to individuals as well as companies, damages can be trebled, and whistleblower provisions let an insider bring the case and share in the recovery.

That last one deserves a moment. The people most likely to know that your affirmation overstated your posture are your own engineers - the ones who told you multifactor authentication was not actually deployed everywhere and watched the number get posted anyway. The enforcement risk is not primarily external discovery. It is internal disagreement that nobody resolved.

The affirming official is not certifying that the program is finished. They are certifying that the description of it is true.

Those two things get conflated constantly, and the conflation is what produces bad affirmations.

An organization with genuine gaps, documented honestly, a POA&M with real dates, and a score that reflects all of it can affirm without exposure. The representation is accurate. It says: here is where we are, and here is the plan. Nobody is defrauded by an accurate account of an incomplete program.

An organization that rounds up - scoring a control as implemented because the purchase order is signed, or because it works in one environment and is "being rolled out" to the others - has made a false statement while feeling like it was being reasonable. The rounding is where the exposure lives, and it never feels like fraud at the time. It feels like optimism about a deployment that is nearly done.

What to demand before signing

Not reassurance. Evidence, and specifically evidence of the controls that were marked implemented most recently, because those are the ones most likely to be aspirational.

Three questions do most of the work. Which controls changed status in the last sixty days, and what evidence supports each change? Which controls are implemented in some environments and not others, and how was that scored? Who disagreed with any scoring decision, and how was it resolved?

The third question is the one nobody asks and the one that matters most. If an engineer objected and was overruled, the affirming official needs to know that before signing, not during a deposition.

None of this argues against self-attestation. Where it is permitted it is faster and cheaper than the alternative, and for a great many contractors it is the correct path. It argues for treating the signature as what it is - a personal representation with statutory consequences - rather than as the last checkbox in an administrative process.

If you want the assessment behind the affirmation run by someone other than the person signing it, that is what a readiness scan is for, and it is a reasonable thing to insist on before your name goes on the line. ◆◆